

Reteste de Invasão

Weather Forecast — versão 6.3.0, comparada com a 6.2.2

Item	Detalhe
Metodologia	OSSTMM 3 (ISECOM), canal Redes de Dados: mesmo roteiro do teste da manhã, mais 1 vetor novo (S4, modo sem internet)
Data	03/10/2026 (teste original e reteste no mesmo dia)
Solicitante	Dalmo Costa
Executor	Claude (assistente de IA), automatizado, com revisão de código
Alvo	Versão 6.3.0 (commit bd180cb), servida localmente de forma idêntica ao publicado; configurações do repositório pela API do GitHub
Resultado	43 de 43 vetores resistiram (antes: 33 de 42). 7 das 11 limitações corrigidas; 4 aceitas e registradas, todas dependentes de infraestrutura ou de decisão de produto

Verdade de partida: o reteste mostra que as falhas de código e de processo encontradas de manhã foram fechadas e comprovadas. O que sobra não se resolve com código no GitHub Pages: privacidade (política e termos antes de vender), cabeçalhos de servidor e serviços gratuitos sem garantia. E continua valendo: **este teste não substitui um pen test profissional antes da venda.**

1. Antes x depois

Medida	6.2.2 (manhã)	6.3.0 (tarde)
Vetores de ataque que resistiram	33 / 42	43 / 43
Limitações abertas	11 (1 alta, 4 médias, 5 baixas, 1 info)	4 aceitas (2 médias, 2 baixas), 0 vulnerabilidades
Ramo main protegido	Não	Sim: ruleset "proteger-main" (e2e + analyze obrigatórios, sem force push, sem exclusão). Push direto sem testes foi recusado (GH013)
2 fatores na conta do dono	Não verificado	Sim: app autenticador, GitHub Mobile, passkey e códigos de recuperação salvos (conferido por print)
Relato privado de falhas	Desligado	Ligado (API: enabled=true)
Alertas e atualizações de segurança do Dependabot	Desligados; 5 atualizações pendentes	Ligados; 5 atualizações aprovadas com testes verdes; 0 pedidos abertos
Secret scanning e push protection	Ligados	Ligados
Acesso do app do Claude	Todos os repositórios (atuais e futuros)	Só os 3 repositórios do dono
npm audit (dependências)	0 vulnerabilidades	0 vulnerabilidades
Pen test no GitHub	Roteiro só local	Roda a cada envio: vetor que volte a falhar barra a publicação

2. Situação de cada limitação

ID	Sev. original	Limitação	Situação	Evidência do reteste
L-01	Alta	Ramo main sem proteção	Corrigida	Ruleset ativo; teste real: push direto recusado; publicação só com e2e + analyze verdes.
L-02	Média	Alarmes desligados e 5 atualizações pendentes	Corrigida	Relato privado, alertas e security updates do Dependabot ligados; 5 PRs aprovados com CI verde.
L-03	Média	Quebra de linha no nome injeta campos no .ics e no e-mail	Corrigida	Vetores F1 e F2 resistiram. cleanText() em todos os serviços; .ics trata \r isolado e U+2028/2029.
L-04	Baixa	Valor interno do JavaScript no armazenamento derruba o site	Corrigida	Vetor S2 (4 variações) resistiu: Object.hasOwn em idioma, unidades e demo.
L-05	Baixa	Endereço do radar sem validação	Corrigida	Vetor C7 resistiu: só *.rainviewer.com em HTTPS e caminho simples. Antes só a CSP segurava.
L-06	Info	Coordenadas vazias ou hexadecimais aceitas	Corrigida	Vetor A2 resistiu: só decimal; vazio, 0x... e 1e1 recusados no link de cidade e de viagem.
L-07	Baixa	Sem cabeçalhos de servidor (GitHub Pages)	Aceita (registrada)	Limitação da hospedagem. Anti-clickjacking por script segue funcionando (K10). Resolver na AWS.
L-08	Média	Dados de localização a terceiros; casa em texto no aparelho	Aceita (registrada)	Por design. Decisão do dono: link com endereço completo. Exige política de privacidade e "apagar meus dados" antes de vender.
L-09	Baixa	CSP com estilo inline e imagens data:/blob:	Aceita (registrada)	Necessário ao mapa e ao radar. Rever na AWS com nonce/hash.
L-10	Baixa	Modo sem internet guarda endereços e buscas	Corrigida	Vetor novo S4 resistiu na 6.3.0 e FALHA na 6.2.2 (55 itens guardados, incluindo o link com "Rua Secreta 10"). Página guardada sem parâmetros; buscas não guardadas; máximo de 30 previsões.
L-11	Média	Serviços gratuitos sem garantia	Aceita (registrada)	Continuidade depende da fase AWS (intermediário com cache e contratos).

3. O que mudou no código (6.3.0)

Arquivo	Mudança
js/domain/text.js (novo)	cleanText(): remove controles C0/C1, DEL, U+2028/2029, marcas bidi e < >. parseCoord(): só decimal, com limite.
js/api/geocoding.js, places.js, road-pois.js	Todos os nomes externos passam por cleanText ao chegar.
js/domain/place-url.js, trip-plan.js	Links: nomes limpos, coordenadas por parseCoord, horário só com dígitos; .ics com \r isolado tratado.
js/i18n/index.js, units-settings.js, app.js	Object.hasOwn para idioma, unidades e cenário demo.
js/api/radar.js	Host e caminho do radar validados antes de montar o endereço das imagens.
sw.js	Página com chave única sem parâmetros; busca de cidades fora do cache; máximo de 30 previsões.
.github/workflows/codeql.yml	CodeQL também nos ramos trabalho/** (o main protegido exige analyze).
tests/	4 testes de tela novos (243/243) e pen test na esteira do GitHub (43/43).

4. Limites deste reteste (honestidade)

- Mesmo método do teste original: IA automatizada, cópia local idêntica ao publicado, serviços externos simulados; canais humano, físico e sem fio fora do escopo.
- Alertas do CodeQL no repositório (lidos por print do dono, a integração recebe 403): 3 alertas "High", **todos em arquivos de teste**, nenhum no site publicado — leitura de arquivo sem trava no servidor de teste, expressão regular sem âncora e comparação de host por pedaço de texto nas simulações. Corrigidos no commit 0171819; o CodeQL fecha os alertas na próxima varredura.
- A proteção da conta Google (o login do GitHub é pelo Google) não é verificável daqui. A verificação em 2 etapas no Google foi recomendada ao dono.
- "Resistiu" significa que o vetor testado não teve sucesso; não prova que não exista outro caminho. Antes de vender: pen test profissional independente.

5. Próximos passos

Quando	Ação	Resolve
Agora	Conferir verificação em 2 etapas na conta Google	Canal humano / conta
Antes de vender	Política de privacidade, termos de uso, botão "apagar meus dados"	L-08
Fase AWS	Cabeçalhos de servidor, CSP mais restrita, intermediário com cache e serviços com contrato	L-07, L-09, L-11
Antes de vender	Pen test profissional independente	Validação externa

Apêndice — os 43 vetores, antes e depois

ID	Área	Vetor	6.2.2	6.3.0
A1	Acesso · link de cidade	código no nome/região/país da cidade no link	RESISTIU	RESISTIU
A2	Acesso · link de cidade	coordenada inválida lat=1e309 lon=0	RESISTIU	RESISTIU
A2	Acesso · link de cidade	coordenada inválida lat=NaN lon=0	RESISTIU	RESISTIU
A2	Acesso · link de cidade	coordenada inválida lat=91 lon=0	RESISTIU	RESISTIU
A2	Acesso · link de cidade	coordenada inválida lat=0 lon=-181	RESISTIU	RESISTIU
A2	Acesso · link de cidade	coordenada inválida lat=0x2A lon=10	FALHOU	RESISTIU
A2	Acesso · link de cidade	coordenada inválida lat= lon=	FALHOU	RESISTIU
A3	Acesso · link de viagem	código nos nomes, horário e veículo do link de viagem	RESISTIU	RESISTIU
A4	Acesso · link de viagem	veículo desconhecido no link	RESISTIU	RESISTIU
A5	Acesso · link de viagem	coordenadas/horário absurdos no link de viagem	RESISTIU	RESISTIU
A6	Acesso · link de cidade	nome gigante (5.000 letras) no link	RESISTIU	RESISTIU
A7	Acesso · parâmetro demo	?demo=__proto__	RESISTIU	RESISTIU
A7	Acesso · parâmetro demo	?demo=constructor	RESISTIU	RESISTIU
A7	Acesso · parâmetro demo	?demo=toString	RESISTIU	RESISTIU
A7	Acesso · parâmetro demo	?demo=<img src=x onerror="window.__x	RESISTIU	RESISTIU
C1	Confiança · busca de cidades (Open-Meteo)	código nos nomes devolvidos pela busca	RESISTIU	RESISTIU
C2	Confiança · busca de cidades (Open-Meteo)	código no nome depois de escolher a cidade (título, barra, favoritos)	RESISTIU	RESISTIU
C3	Confiança · busca de endereços (Photon)	código em rua/número/cidade devolvidos	RESISTIU	RESISTIU
C4	Confiança · alertas oficiais (NWS)	código no texto do alerta oficial	RESISTIU	RESISTIU
C5	Confiança · postos/balanças (Overpass) e nomes no caminho (BigDataCloud)	código nos nomes de postos, balanças e cidades do caminho, inclusive nas dicas do mapa	RESISTIU	RESISTIU
C6	Confiança · previsão (Open-Meteo)	previsão com tipos errados/código no lugar de números	RESISTIU	RESISTIU
C7	Confiança · radar (RainViewer)	serviço de radar manda buscar imagens em outro domínio	FALHOU	RESISTIU
S1	Armazenamento local	código em cidade salva, favoritas, viagens recentes, casa, unidades e idioma	RESISTIU	RESISTIU
S2	Armazenamento local	idioma/unidade salvos como "constructor" (palavra interna do JavaScript)	FALHOU	RESISTIU
S2	Armazenamento local	idioma/unidade salvos como "__proto__" (palavra interna do JavaScript)	FALHOU	RESISTIU
S2	Armazenamento local	idioma/unidade salvos como "toString" (palavra interna do JavaScript)	FALHOU	RESISTIU
S2	Armazenamento local	idioma/unidade salvos como "hasOwnProperty" (palavra interna do JavaScript)	FALHOU	RESISTIU
S3	Armazenamento local	dados corrompidos (não-JSON, tipos errados)	RESISTIU	RESISTIU
K1	Controles · integridade	scripts de terceiros carregados na página	RESISTIU	RESISTIU
K2	Controles · CSP	script inserido na página é bloqueado pela política (CSP)	RESISTIU	RESISTIU
K3	Controles · CSP	atributo de evento injetado no HTML (onerror=...) é bloqueado	RESISTIU	RESISTIU

ID	Área	Vetor	6.2.2	6.3.0
K4	Controles · CSP	script de outro domínio bloqueado	RESISTIU	RESISTIU
K5	Controles · CSP	envio de dados para domínio não autorizado (fetch) bloqueado	RESISTIU	RESISTIU
K6	Controles · links externos	links que abrem nova aba sem rel=noopener (tabnabbing)	RESISTIU	RESISTIU
K7	Controles · transporte	recursos por http (sem criptografia) no HTML	RESISTIU	RESISTIU
K8	Privacidade · cabeçalho Referer	site manda a página completa (com cidade/viagem) para terceiros	RESISTIU	RESISTIU
K9	Privacidade · terceiros	serviços externos contatados ao abrir	RESISTIU	RESISTIU
S4	Armazenamento · modo sem internet	endereço de viagem (no link) ou busca digitada ficam guardados no aparelho	(novo)	RESISTIU
K10	Controles · clickjacking	outro site embute o nosso num iframe invisível	RESISTIU	RESISTIU
F1	Integridade · arquivo de calendário (.ics)	quebra de linha no nome da cidade cria campo falso no convite (ex.: convidado do atacante)	FALHOU	RESISTIU
F2	Integridade · e-mail (mailto)	cabeçalhos extras no e-mail (cc/bcc) a partir do nome	FALHOU	RESISTIU
R1	Resiliência	busca com 5.000 letras	RESISTIU	RESISTIU
R2	Resiliência	digitação muito rápida (30 letras) não vira 30 consultas	RESISTIU	RESISTIU